



seguridad/si
ciberseguridad

AUDITORÍA COMPLETA

Abril 2026

1. PRESENTACIÓN DE EMPRESA

SEGURIDAD/SI nace con objetivo de ampliar y mejorar el catálogo de soluciones y servicios adaptados a las necesidades de nuestros clientes y acercar la mejor tecnología sin perder los valores de orientación al cliente, auto exigencia y calidad.

“Más que un servicio o un producto, un aliado tecnológico en el ámbito de la ciberseguridad”

Nuestro equipo de trabajo se compone de profesionales ampliamente reconocidos en el sector, con más de 20 años de experiencia algunos en la ciberseguridad, y otros miembros con menos experiencia pero con una proyección y conocimientos, y sobre todo, con ilusión y vocación por el cliente.

Principales clientes

2. OBJETIVOS DEL PROYECTO

Establecido como objetivo principal del proyecto la contratación de un servicio profesional de ciberseguridad que permita una evaluación detallada del nivel de seguridad mediante un análisis a nivel técnico.

El resultado de los servicios será un informe ejecutivo presentando de forma definitiva los resultados obtenidos durante el proceso de auditoría.

3. SERVICIOS PROPUESTOS

3.1. Auditoría de ciberseguridad

Durante el diagnóstico que realizará el equipo de ciberseguridad de Seguridad SI se procederá a recopilar toda la información sobre los activos a evaluar en la organización. Este paso es extremadamente importante ya que supone la base del test de intrusión.

Durante el diagnóstico de ciberseguridad se llevarán a cabo las siguientes fases:

- **Recopilación de información:** El equipo de seguridad obtendrá el mayor número de información sobre los sistemas, la organización y sus usuarios en fuentes públicas a través de herramientas automatizadas, consultas a motores de búsquedas y pruebas manuales.
- **Detección de sistemas:** Tras la recopilación de información sobre los activos, se identificarán los posibles sistemas dentro del alcance del presente acuerdo.
- **Reconocimiento:** Identificación de nuevos equipos a través de servidores DNS, herramientas automatizadas y consultas específicas.
- **Identificación de Servicios:** Una vez establecida la lista de activos a auditar, tanto los ofrecidos por el cliente como los nuevos descubiertos se procederá a identificar los servicios ofrecidos por los mismos. Registrando las herramientas utilizadas durante el proceso y sus versiones.
En la fase de explotación se procederá a identificar y explotar las vulnerabilidades descubiertas.
- **Identificación de vulnerabilidades:** Una de las tareas más laboriosas y críticas es, detectar fallos de seguridad en los activos analizados. El equipo de SEGURIDAD SI llevará a cabo un análisis automático y manual de las vulnerabilidades detectadas en los recursos de la organización durante la fase de identificación de servicios.
- **Enumeración de activos:** Fase donde el equipo de analistas identificará cuales son los puntos de entrada que probablemente faciliten el acceso a la red interna del cliente.

No sólo los que nos proporcione el cliente sino los que el equipo de SEGURIDAD/SI encuentre durante la fase de reconocimiento.

- **Explotación:** Tras haber identificado los activos vulnerables, se procederá a explotar sus vulnerabilidades que ya se habrán identificado en fases anteriores. En el supuesto caso de que se gane acceso a un activo de forma remota este se puede utilizar como pivote para intentar penetrar en el núcleo de los sistemas de la organización, siempre y cuando el acuerdo de “Reglas de compromiso” no diga lo contrario.

Una vez finalizada la fase de explotación comenzaremos con la elaboración del informe en el que se documentará las vulnerabilidades y las recomendaciones que permitirán elevar el nivel de seguridad perimetral e interno del cliente.

- **Análisis de resultados:** El equipo de seguridad encargado de realizar el hacking ético analizará la información obtenida con el objetivo de identificar el impacto que esta puede suponer para la entidad.
- **Análisis de impacto:** En esta fase se mide el posible riesgo al cual se está expuesto, determinando el impacto de la explotación de las vulnerabilidades y su probabilidad de ser atacado por esos vectores de entrada, los cuales supondría los siguientes riesgos:
 - **Riesgo de pérdidas:** referente a la posible fuga o robo de información.
 - **Riesgo en los procesos:** debido a posibles ataques de denegación de servicio.
 - **Riesgo técnico:** presencia de vulnerabilidades en los activos.
 - **Riesgo Organizativo:** a modo de métrica del nivel de riesgo global.

La finalidad del diagnóstico es poner a prueba la capacidad de detección/resistencia de la organización ante un ataque externo. Por cada una de las vulnerabilidades encontradas durante el análisis de hacking ético, el equipo de Seguridad SI establecerá un plan de sanitización dentro de las siguientes categorías:

- **Mejoras inmediatas:** Un atacante puede hacerse con el control del sistema o puede obtener información altamente sensible. Las vulnerabilidades de este nivel pueden incluir el acceso completo de lectura de archivos, potenciales puertas traseras o listas de usuarios y contraseñas.
- **Mejoras a corto plazo:** El atacante puede obtener información específica almacenada en el activo, incluyendo la configuración de seguridad. Las vulnerabilidades de este nivel pueden incluir la divulgación parcial del contenido de los archivos, el acceso a

ciertos archivos en el equipo, la explotación de directorios, ataques de denegación de servicio o el uso no autorizado de servicios.

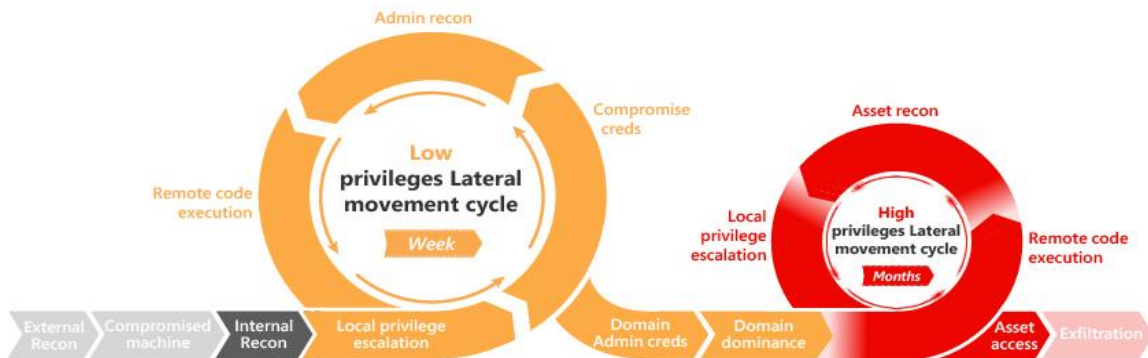
- **Mejoras a medio plazo:** El atacante puede obtener información del activo, como la versión exacta del software instalado. Con esta información un atacante puede explorar fácilmente vulnerabilidades conocidas específicas para la versión localizada.
- **Mejoras a largo plazo:** Presencia de vulnerabilidades o problemas que puedan degradar considerablemente la seguridad a largo plazo.

Adicionalmente cada problema de seguridad identificado por el equipo de analistas será descrito de manera concisa junto con la vulnerabilidad y el nivel de destreza requerida por un atacante. Las vulnerabilidades vienen complementadas por una o varias medidas correctivas para solventar o mitigar la deficiencia identificada.

La calificación de impacto refleja aquello que un atacante podría obtener al explotarlas vulnerabilidades descritas y el consecuente riesgo. En la siguiente tabla muestra la relación existente entre el riesgo asignado a la vulnerabilidad y la puntuación según el CVSS:

Riesgo	CVSS
NULO	0.0
BAJO	0.1 - 3.9
MEDIO	4.0 - 6.9
ALTO	7.0 - 8.9
CRÍTICO	9.0 - 10.0

En el proceso de diagnóstico interno se realizan pruebas para comprobar que un usuario concreto tiene acceso a los recursos que le corresponden en base a su perfil corporativo. Para ello se realizan diferentes acciones ofensivas y se mide el estado de seguridad de la organización, simulando un ataque desde el punto de vista de alguien que haya podido acceder a la red interna mediante un ataque perimetral.



Los conceptos de seguridad que se miden en un diagnóstico interno, añadidos a los anteriormente expuestos son:

- Escalada de privilegios local y dominio.
- Movimientos laterales para acceder al máximo número posible de equipos.
- Evasión de medidas de seguridad.

En el caso necesario, se evaluarían las capacidades de persistencia y exfiltración de información.

En resumen, todo un conjunto de técnicas y tácticas empleadas por los cibercriminales para conseguir vulnerar la seguridad de la organización.

Durante el diagnóstico **se realizará una investigación profunda para detectar si la organización ha sido comprometida con anterioridad**. Se analizará la presencia de malware, rootkits, webshells en servicios críticos, así como se analizarán las filtraciones de claves expuestas en Internet, redes TOR y similares. Este servicio **no es un análisis forense**, que podrá ser cotizado en una propuesta adicional.

Estándares de seguridad

El definir una serie de pautas, procedimientos y metodologías permitirá obtener una información imparcial que puede ser comprobable, repetible y que sirva para hacer un seguimiento sobre el alineamiento de las necesidades del cliente. De este modo quedarán definidas qué pruebas se realizan y de qué forma se ejecutan.

La metodología a utilizar está basada en los estándares de seguridad Ms Cyber Kill Chain, ENS y OSSTMM.

Por otro lado, **OSSTM** se ha convertido en una referencia para los organismos que quieren desarrollar un testing de calidad, ordenado y eficiente. Para organizar su contenido, la metodología se subdivide en los aspectos más importantes de los sistemas de información:

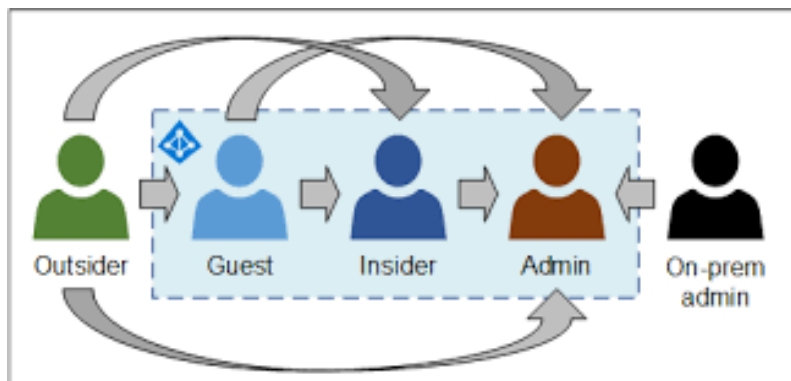


1. Seguridad de la Información
2. Seguridad de los Procesos
3. Seguridad en las Tecnologías de Internet
4. Seguridad en las Comunicaciones
5. Seguridad Inalámbrica

Tipología de intrusión

En este tipo de proyectos se puede enfocar el diagnóstico de dos formas: “caja negra” o “caja gris”. La diferencia de planteamientos reside en que el trabajo se realiza con **más o menos información** previa proporcionada por el cliente, como pueda ser direccionamiento IP, usuarios y contraseñas, etc.

Para el caso que nos ocupa se llevarán a cabo los trabajos bajo ambos formatos (**caja negra y caja gris**) de cara a poder obtener una perspectiva de seguridad lo más integral posible.



Ejemplo de Herramientas empleadas



Modelo de gobierno del proyecto

Para el proyecto objeto de esta propuesta se plantea el siguiente modelo de gestión:

1. **Reunión de kick-off:** reunión inicial de arranque del proyecto para la puesta en común de interlocutores y alcances detallados de los trabajos. **Frecuencia:** Inicio de proyecto
2. **Reuniones técnicas:** se trata de reuniones entre los diferentes interlocutores técnicos tanto de SeguridadSI como del cliente para el desarrollo de las tareas requeridas por el proyecto. **Frecuencia:** Bajo Demanda
3. **Reuniones de seguimiento:** en estas reuniones la dirección de proyecto consensuará el adecuado alineamiento de la ejecución del proyecto con la planificación del mismos, así como la identificación de posibles situaciones que requieran de un plan de acción por parte de SeguridadSI. **Frecuencia:** Bajo Demanda
4. **Reunión de presentación de resultados:** en estas reuniones se presentarán los resultados de la auditoría tanto a los equipos técnicos como a los directivos. **Frecuencia:** Única
5. **Reunión de cierre:** en esta reunión se revisará el adecuado cumplimiento de los objetivos del proyecto y los potenciales mecanismos de seguimiento que pudiera requerir el mismo. Además, se evaluarán posibles próximos pasos en el caso de que fuera necesaria la generación de nuevos proyectos. **Frecuencia:** Única
6. **Seguimiento de resultados:** Una vez concluida la auditoría y presentados los resultados de la misma se ofrece una plataforma de soporte a consultas relativas a solventar las vulnerabilidades encontradas, impacto y consecuencias de las actualizaciones o cambios necesarios para corregir los hallazgos o como verificar los parches aplicados por el equipo IT del cliente. **Frecuencia:** Continua

Nota: La interlocución entre el cliente y SeguridadSI para el seguimiento de resultados se realizará a través de correo electrónico y teléfono.

4. ALCANCE

4.1. Consideraciones generales

Antes de comenzar la ejecución del **proyecto de auditoría** el cliente se compromete a cumplir ciertas condiciones que permiten llevar a cabo el proyecto dentro de los plazos estipulados. Las mismas se recogen a continuación:

- Designación por parte de la empresa de un interlocutor válido.
- Autorización del departamento IT sobre el alcance del servicio.
- La franja horaria en la que se realizarán las pruebas las indicará el cliente.
- Coordinación con el equipo analista para la ventana de realización de las pruebas.
- Ataque bajo control del servicio. No se realizan ataques de denegación de servicios intencionados.
- Reporte inmediato de incidencias críticas si las hubiera, coordinación para la implementación de medidas correctoras.
- El equipo analista se encargará de enviar un correo de inicio y fin en los primeros días de la auditoría.
- Proporcionar, en caso de necesidad, los accesos remotos y usuarios necesarios para la realización de los análisis de seguridad internos necesarios.
- En caso de caída involuntaria de un servicio, será responsabilidad del cliente junto con la ayuda del equipo de analistas, restablecer el servicio de forma conveniente.

4.2. Ámbito de actuación

El ámbito de actuación viene definido por las conversaciones establecidas en el inicio del proyecto. (Auditoría Externa, Auditoría Interna, Auditoría 360, Auditoría Cloud.)

4.3. Servicios no incluidos

- No se incluye en la oferta la auditoría de servicios de intrusión física para evadir medidas de seguridad como puedan ser cerraduras, cámaras, alarmas, puertas, habitaciones, etc.
- No se incluyen en el diagnóstico las pruebas específicas de soluciones inalámbricas como Wifi, Bluetooth, NFC, RFID, etc. Sin embargo, sí se hará un estudio básico del planteamiento de seguridad empleado en las mismas.
- No se incluye en la propuesta un plan de contingencia en caso de desastre. Una vez se disponga de la información de auditoría y se conozca la infraestructura de red (número de servidores, número de sedes, cómo se realizan las copias de seguridad, estado de las cabinas de disco, servidores virtualizados, etc) se podrá plantear un plan de contingencia.
- En caso de caída involuntaria de un servicio, sería responsabilidad del cliente, junto con la ayuda del equipo de analistas, de restablecer el servicio.
- La realización del diagnóstico no incluye test de carga o que realicen denegaciones de servicio programadas. Sin embargo, se puede dar el caso de que un sistema poco robusto sufra mermas en la calidad del servicio.

**Estos servicios podrán ofrecerse como complemento a esta oferta y serán objeto de cotización adicional.*

5. VALORACIÓN ECONÓMICA

A continuación, se muestra la valoración económica de los servicios profesionales para dar cumplimiento del alcance propuesto.

PROYECTO DE SEGURIDAD			
Descripción	Medición	PVP Unitario	PVP Total
Auditoria Interna	1		3.600,00 €
Auditoria Externa	1		2.800,00 €
Auditoria Cloud	1		2.800,00 €
Informe 360	1		750,00 €
Presentación Presencial	1		750,00 €
Soporte 10 horas/ 2 meses documento	1		800,00 €
*Todas las auditorías en modalidad caja negra y caja gris			
			11.500,00 €
TOTAL			7.800,00 €

IVA No incluido

- Para el cálculo del descuento y dedicación, se ha tenido en cuenta la realización completa
- Duración estimada de puesta en marcha del proyecto
- El servicio tendrá una duración de 1 mes.
- Plazo de validez de la oferta
- Validez del presupuesto: 30 días
- Inicio de los trabajos: Una semana tras la firma del presupuesto.

6. EL AUDITOR



Joaquín Molina- kinomakino

Apasionado de la informática y de la seguridad desde mediados de los 90. Cuenta con numerosas certificaciones y pertenece a organizaciones de reconocido nombre como ENISA y ha obtenido premio Microsoft MVP los últimos 9 años.

Creador del blog sobre ciberseguridad INSEGUROS Seguridad Informática.

Ponente en las más importantes conferencias nacionales e internacionales.

7. ANEXO

Todos los materiales y servicios no contemplados en el presente quedan excluidos del proyecto.

SEGURIDAD/SI se compromete a dar un trato reservado y confidencial a toda la información que pudieran obtener del Cliente, a procurar su custodia y a no ser divulgada por el personal a su cargo, salvo mediación de la autorización pertinente y por escrito por parte Cliente.

SEGURIDAD/SI garantizará la seguridad y la confidencialidad de toda la documentación e información de que disponga sobre la infraestructura de red corporativa y sistemas informáticos del Cliente, así como de toda la información que circule por la red a través de la que se preste el servicio de soporte.

Queda prohibida la difusión y/o distribución a terceros de datos y documentos proporcionados por el Cliente u obtenidos a través de este, cuando estas actividades no respondan a necesidades exigidas para la realización de tareas vinculadas al presente proyecto, y sin la autorización expresa del Cliente.

SEGURIDAD SI quedará obligada al cumplimiento de lo dispuesto en la Ley Orgánica 15/1999 de 13 de diciembre, de Protección de Datos de Carácter Personal (LOPD) y en el artículo 28 del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 (RGDP), así como a los preceptos de dichas leyes.

Ambas partes, con renuncia de su propio fuero, si lo tuvieran, se someten a los juzgados y tribunales de Murcia para la discusión litigiosa de este acuerdo.

Todos los materiales y servicios no contemplados en el presente quedan excluidos del proyecto.

Las fechas de entrega, realización de cursos y demás podrán verse modificadas previo acuerdo con el interesado y siempre que no le ocasione perjuicio alguno al cliente.